



Web 应用程序报告

该报告包含有关 **web** 应用程序的重要安全信息。

安全报告

该报告由 IBM Security AppScan Standard 创建 9.0.3.6, 规则: 10344
扫描开始时间: 2021/5/8 12:05:39

目录

介绍

- 常规信息
- 登陆设置

摘要

- 问题类型
- 有漏洞的 URL
- 修订建议
- 安全风险
- 原因
- WASC 威胁分类

按问题类型分类的问题

- Oracle Application Server PL/SQL 未授权的 SQL 查询执行 ②
- Oracle 日志文件信息泄露 ②
- 临时文件下载 ②
- 发现压缩目录 ⑮
- 发现潜在订单信息 ②
- 归档文件下载 ②
- 缺少“Content-Security-Policy”头 ③
- 缺少“X-Content-Type-Options”头 ①
- 缺少“X-XSS-Protection”头 ①
- HTML 注释敏感信息泄露 ①
- 发现电子邮件地址模式 ①
- 客户端（JavaScript）Cookie 引用 ①
- 检测到应用程序测试脚本 ⑬

修订建议

- 阻止对 PL/SQL 过程和应用程序进行未认证的 PUBLIC 访问
- 不要在可以轻易猜测到的文件名中保存敏感信息，或者限制对它们的访问
- 关闭跟踪，限制对日志文件的访问，或者将其除去
- 将您的服务器配置为使用“Content-Security-Policy”头
- 将您的服务器配置为使用“X-Content-Type-Options”头
- 将您的服务器配置为使用“X-XSS-Protection”头
- 除去 HTML 注释中的敏感信息
- 除去 Web 站点中的电子邮件地址
- 除去压缩目录文件或限制对它的访问
- 除去客户端中的业务逻辑和安全逻辑
- 除去服务器中的测试脚本
- 除去虚拟目录中的旧版本文件

咨询

- Oracle Application Server PL/SQL 未授权的 SQL 查询执行
- Oracle 日志文件信息泄露
- 临时文件下载
- 发现压缩目录
- 发现潜在订单信息
- 归档文件下载
- 缺少“Content-Security-Policy”头
- 缺少“X-Content-Type-Options”头
- 缺少“X-XSS-Protection”头
- HTML 注释敏感信息泄露
- 发现电子邮件地址模式
- 客户端（JavaScript）Cookie 引用
- 检测到应用程序测试脚本

应用程序数据

- cookie
- JavaScript
- 参数
- 注释
- 已访问的 URL
- 失败的请求
- 已过滤的 URL

介绍

该报告包含由 IBM Security AppScan Standard 执行的 Web 应用程序安全性扫描的结果。

高严重性问题:	2
低严重性问题:	28
参考严重性问题:	16
报告中包含的严重性问题总数:	46
扫描中发现的严重性问题总数:	46

常规信息

扫描文件名称:	未命名
扫描开始时间:	2021/5/8 12:05:39
测试策略:	Default

主机	sx.baway.tech
端口	0
操作系统:	未知
Web 服务器:	未知
应用程序服务器:	任何

登陆设置

登陆方法:	无
-------	---

摘要

问题类型 13

TOC

问题类型	问题的数量
高 Oracle Application Server PL/SQL 未授权的 SQL 查询执行	2
低 Oracle 日志文件信息泄露	2
低 临时文件下载	2
低 发现压缩目录	15
低 发现潜在订单信息	2
低 归档文件下载	2
低 缺少“Content-Security-Policy”头	3
低 缺少“X-Content-Type-Options”头	1
低 缺少“X-XSS-Protection”头	1
参 HTML 注释敏感信息泄露	1
参 发现电子邮件地址模式	1
参 客户端（JavaScript）Cookie 引用	1
参 检测到应用程序测试脚本	13

有漏洞的 URL 7

TOC

URL	问题的数量
高 http://sx.baway.tech:8060/dev-api/	3
低 http://sx.baway.tech:8060/dev-api/captchalimage	4
低 http://sx.baway.tech:8060/dev-api/login	3
低 http://sx.baway.tech:8060/static/js/67.js	3
参 http://sx.baway.tech:8060/	1
参 http://sx.baway.tech:8060/static/js/10.js	1
参 http://sx.baway.tech:8060/static/js/chunk-vendors.js	1

修订建议 12

TOC

修复任务	问题的数量
高 阻止对 PL/SQL 过程和应用程序进行未认证的 PUBLIC 访问	2
低 不要在可以轻易猜测到的文件名中保存敏感信息，或者限制对它们的访问	2
低 关闭跟踪，限制对日志文件的访问，或者将其除去	2
低 将您的服务器配置为使用“Content-Security-Policy”头	3
低 将您的服务器配置为使用“X-Content-Type-Options”头	1
低 将您的服务器配置为使用“X-XSS-Protection”头	1
低 除去 HTML 注释中的敏感信息	1
低 除去 Web 站点中的电子邮件地址	1
低 除去压缩目录文件或限制对它的访问	15
低 除去客户端中的业务逻辑和安全逻辑	1
低 除去服务器中的测试脚本	13
低 除去虚拟目录中的旧版本文件	4

安全风险 6

TOC

风险	问题的数量
高 可能会查看、修改或删除数据库条目和表	2
低 可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置	11
低 可能会下载临时脚本文件，这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息	17
低 可能会检索服务器端脚本的源代码，这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息	15
低 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息	5
参 此攻击的最坏情形取决于在客户端所创建的 cookie 的上下文和角色	1

原因 5

TOC

原因	问题的数量
高 Web 应用程序编程或配置不安全	25
低 Web 服务器或应用程序服务器是以不安全的方式配置的	2

低	在生产环境中留下临时文件	17	
参	程序员在 Web 页面上留下调试信息	1	
参	Cookie 是在客户端创建的	1	

WASC 威胁分类

[TOC](#)

威胁	问题的数量	
SQL 注入	2	
信息泄露	27	
可预测资源位置	17	

按问题类型分类的问题

高

Oracle Application Server PL/SQL 未授权的 SQL 查询执行 2

TOC

问题 1 / 2

TOC

Oracle Application Server PL/SQL 未授权的 SQL 查询执行

严重性: 高

CVSS 分数: 9.7

URL: <http://sx.baway.tech:8060/dev-api/>

实体: owa_util.signature (Page)

风险: 可能会查看、修改或删除数据库条目和表

原因: Web 应用程序编程或配置不安全

固定值: 阻止对 PL/SQL 过程和应用程序进行未认证的 PUBLIC 访问

差异: 路径 从以下位置进行控制: </dev-api/captchaImage> 至: /dev-api/owa_util.signature

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

未经处理的测试响应:

```
...
GET /dev-api/owa_util.signature HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 97
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:20:30 GMT
content-type: application/json;charset=utf-8
```

```
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /owa_util.signature, 认证失败, 无法访问系统资源", "code": 401}
...
```

问题 2 / 2

TOC

Oracle Application Server PL/SQL 未授权的 SQL 查询执行

严重性: **高**

CVSS 分数: 9.7

URL: <http://sx.baway.tech:8060/dev-api/>

实体: owa_util.listprint (Page)

风险: 可能会查看、修改或删除数据库条目和表

原因: Web 应用程序编程或配置不安全

固定值: 阻止对 PL/SQL 过程和应用程序进行未认证的 PUBLIC 访问

差异: 路径 从以下位置进行控制: </dev-api/captchaImage> 至: /dev-api/owa_util.listprint
查询 从以下位置进行控制: [--](#) 至: [p_theQuery=SELECT%20*%20FROM%20SYS.TAB&p_cname=&p_nsize=](#)

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

未经处理的测试响应:

```
...
GET /dev-api/owa_util.listprint?p_theQuery=SELECT%20*%20FROM%20SYS.TAB&p_cname=&p_nsize= HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 97
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:20:30 GMT
content-type: application/json;charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /owa_util.listprint, 认证失败, 无法访问系统资源", "code": 401}
...
```

问题 1 / 2

TOC

Oracle 日志文件信息泄露

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: sqlnet.log (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置

原因: Web 服务器或应用程序服务器是以不安全的方式配置的

固定值: 关闭跟踪, 限制对日志文件的访问, 或者将其除去

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/sqlnet.log`

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

未经处理的测试响应:

```
...
GET /dev-api/sqlnet.log HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 89
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:14:46 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /sqlnet.log, 认证失败, 无法访问系统资源", "code": 401}
...
```

Oracle 日志文件信息泄露

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: sqlnet.trc (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置

原因: Web 服务器或应用程序服务器是以不安全的方式配置的

固定值: 关闭跟踪, 限制对日志文件的访问, 或者将其除去

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/sqlnet.trc`

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

未经处理的测试响应:

```
...
GET /dev-api/sqlnet.trc HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 89
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:14:46 GMT
content-type: application/json;charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg":"请求访问: /sqlnet.trc, 认证失败, 无法访问系统资源","code":401}
...
```

低

临时文件下载 2

TOC

临时文件下载

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/login>

实体: login (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去虚拟目录中的旧版本文件

差异: 方法 从以下位置进行控制: POST 至: GET

主体 从以下位置进行控制:

```
{"username": "32", "password": "123456", "code": "32", "uuid": "01d2a348477347d5bc65aff88a2cd612", "key": "student"}
```

至: -

标题 已从请求除去: application/json; charset=UTF-8

路径 从以下位置进行控制: /dev-api/login 至: /dev-api/login.lzma

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...

User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Origin: http://sx.baway.tech:8060
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 89
x-content-type-options: nosniff
expires: 0
access-control-allow-origin: http://sx.baway.tech:8060
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
vary: Origin, Access-Control-Request-Method, Access-Control-Request-Headers
date: Sat, 08 May 2021 04:18:22 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate
access-control-allow-credentials: true

{"msg": "请求访问: /login.lzma, 认证失败, 无法访问系统资源", "code": 401}
...
```

临时文件下载

严重性: **低**

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/captchaImage>

实体: captchaImage (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去虚拟目录中的旧版本文件

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/captchaImage.lzma`

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api/captchaImage.lzma HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 96
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:18:01 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /captchaImage.lzma, 认证失败, 无法访问系统资源", "code": 401}
...
```

低

发现压缩目录 15

TOC

问题 1 / 15

TOC

发现压缩目录

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.zip (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: /dev-api/captchaImage 至: /dev-api/dev-api.zip

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api/dev-api.zip HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 90
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:15:27 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /dev-api.zip, 认证失败, 无法访问系统资源", "code": 401}
...
```

发现压缩目录

严重性: **低**

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.tar.lzma (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api.tar.lzma`

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api.tar.lzma HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 88
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:13 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /.tar.lzma, 认证失败, 无法访问系统资源", "code": 401}
...
```

发现压缩目录

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.gz (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: /dev-api/captchaImage 至: /dev-api/dev-api.gz

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api/dev-api.gz HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 89
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:15:27 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /dev-api.gz, 认证失败, 无法访问系统资源", "code": 401}
...
```

发现压缩目录

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.rar (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: /dev-api/captchaImage 至: /dev-api/dev-api.rar

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api/dev-api.rar HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 90
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:15:27 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /dev-api.rar, 认证失败, 无法访问系统资源", "code": 401}
...
```

发现压缩目录

严重性: **低**

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.ar (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api.ar`

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api.ar HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 82
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:14 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg":"请求访问: /.ar, 认证失败, 无法访问系统资源","code":401}
...
```

发现压缩目录

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.ace (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: /dev-api/captchaImage 至: /dev-api/dev-api.ace

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api/dev-api.ace HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 90
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:15:27 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /dev-api.ace, 认证失败, 无法访问系统资源", "code": 401}
...
```

发现压缩目录

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.wim (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api.wim`

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api.wim HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 83
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:16 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /.wim, 认证失败, 无法访问系统资源", "code": 401}
...
```

发现压缩目录

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.lha (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: /dev-api/captchaImage 至: /dev-api/dev-api.lha

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api/dev-api.lha HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 90
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:15:30 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /dev-api.lha, 认证失败, 无法访问系统资源", "code": 401}
...
```

发现压缩目录

严重性: **低**

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.lzh (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/dev-api.lzh`

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api/dev-api.lzh HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 90
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:15:30 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /dev-api.lzh, 认证失败, 无法访问系统资源", "code": 401}
...
```

发现压缩目录

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.tar (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: /dev-api/captchaImage 至: /dev-api/dev-api.tar

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api/dev-api.tar HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 90
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:15:30 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /dev-api.tar, 认证失败, 无法访问系统资源", "code": 401}
...
```

发现压缩目录

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.arj (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: /dev-api/captchaImage 至: /dev-api/dev-api.arj

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api/dev-api.arj HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 90
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:15:30 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /dev-api.arj, 认证失败, 无法访问系统资源", "code": 401}
...
```

发现压缩目录

严重性: **低**

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.arc (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/dev-api.arc`

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api/dev-api.arc HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 90
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:15:30 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /dev-api.arc, 认证失败, 无法访问系统资源", "code": 401}
...
```

发现压缩目录

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.war (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: /dev-api/captchaImage 至: /dev-api.war

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api.war HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 83
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:22 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg":"请求访问: /.war, 认证失败, 无法访问系统资源","code":401}
...
```

发现压缩目录

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.tar.gz (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: /dev-api/captchaImage 至: /dev-api/dev-api.tar.gz

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api/dev-api.tar.gz HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 93
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:15:31 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /dev-api.tar.gz, 认证失败, 无法访问系统资源", "code": 401}
...
```

发现压缩目录

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: dev-api.ear (Page)

风险: 可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 除去压缩目录文件或限制对它的访问

差异: 路径 从以下位置进行控制: /dev-api/captchaImage 至: /dev-api.ear

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api.ear HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 83
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:05 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /.ear, 认证失败, 无法访问系统资源", "code": 401}
...
```

低

发现潜在订单信息 2

TOC

问题 1 / 2

TOC

发现潜在订单信息

严重性: **低**

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: order.txt (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置

原因: Web 应用程序编程或配置不安全

固定值: 不要在可以轻易猜测到的文件名中保存敏感信息, 或者限制对它们的访问

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/order.txt`

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求:

```
GET /dev-api/order.txt HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

测试响应

```
...
GET /dev-api/order.txt HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 88
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:15:13
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate
```

```
{"msg": "请求访问: /order.txt, 认证
失败, 无法访问系统资源", "code": 401}
...
```

发现潜在订单信息

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: order.htm (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置

原因: Web 应用程序编程或配置不安全

固定值: 不要在可以轻易猜测到的文件名中保存敏感信息, 或者限制对它们的访问

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/order.htm`

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求:

测试响应

```
GET /dev-api/order.htm HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
...
GET /dev-api/order.htm HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 88
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:15:14
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate
```

```
{"msg":"请求访问: /order.htm, 认证
失败, 无法访问系统资源", "code":401}
...
```

低

归档文件下载 2

TOC

问题 1 / 2

TOC

归档文件下载

严重性: **低**

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/login>

实体: login (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去虚拟目录中的旧版本文件

差异: 方法 从以下位置进行控制: **POST** 至: **GET**

主体 从以下位置进行控制:

```
{"username":"32","password":"123456","code":"32","uuid":"01d2a348477347d5bc65aff88a2cd612","key":"student"}
```

至: -

标题 已从请求除去: **application/json; charset=UTF-8**

路径 从以下位置进行控制: **/dev-api/login** 至: **/dev-api/login.arc**

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...

User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Origin: http://sx.baway.tech:8060
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 88
x-content-type-options: nosniff
expires: 0
access-control-allow-origin: http://sx.baway.tech:8060
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
vary: Origin, Access-Control-Request-Method, Access-Control-Request-Headers
date: Sat, 08 May 2021 04:18:11 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate
access-control-allow-credentials: true

{"msg":"请求访问: /login.arc, 认证失败, 无法访问系统资源","code":401}
...
```

归档文件下载

严重性: **低**

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/captchaImage>

实体: captchaImage (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去虚拟目录中的旧版本文件

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/captchaImage.arc`

推理: AppScan 接收到响应状态“200 OK”, 而且内容类型与请求的文件扩展名匹配。

未经处理的测试响应:

```
...
GET /dev-api/captchaImage.arc HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 95
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:17:47 GMT
content-type: application/json; charset=utf-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate

{"msg": "请求访问: /captchaImage.arc, 认证失败, 无法访问系统资源", "code": 401}
...
```

低

缺少“Content-Security-Policy”头 3

TOC

问题 1 / 3

TOC

缺少“Content-Security-Policy”头

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/static/js/67.js>

实体: 67.js (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 将您的服务器配置为使用“Content-Security-Policy”头

差异:

推理: AppScan 检测到 Content-Security-Policy 响应头缺失，这可能会更大程度得暴露于各种跨站点注入攻击下之

未经处理的测试响应:

```
...
GET /static/js/67.js HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
Connection: keep-alive
Accept-Ranges: bytes
Content-Length: 102495
Keep-Alive: timeout=5
X-Powered-By: Express
ETag: W/"1905f-6RXUrf1m70QJ4/0kYdTab49hYJQ"
Date: Sat, 08 May 2021 04:12:21 GMT
Content-Type: application/javascript; charset=UTF-8

((typeof self !== 'undefined' ? self : this)["webpackJsonp"] = (typeof self !== 'undefined' ?
self : this)["webpackJsonp"] || []).push([[67],{
...

```

缺少“Content-Security-Policy”头

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/login>

实体: login (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 将您的服务器配置为使用“Content-Security-Policy”头

差异:

推理: AppScan 检测到 Content-Security-Policy 响应头缺失, 这可能会更大程度得暴露于各种跨站点注入攻击下之

未经处理的测试响应:

```
...

{
  "username": "32",
  "password": "123456",
  "code": "32",
  "uuid": "01d2a348477347d5bc65aff88a2cd612",
  "key": "student"
}

HTTP/1.1 200 OK
x-content-type-options: nosniff
expires: 0
access-control-allow-origin: http://sx.baway.tech:8060
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
vary: Origin, Access-Control-Request-Method, Access-Control-Request-Headers
date: Sat, 08 May 2021 04:12:20 GMT
content-type: application/json;charset=UTF-8

...

...

connection: close
vary: Origin, Access-Control-Request-Method, Access-Control-Request-Headers
date: Sat, 08 May 2021 04:12:20 GMT
content-type: application/json;charset=UTF-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate
transfer-encoding: chunked
access-control-allow-credentials: true

{"msg": "验证码已失效", "code": 500}
...
```

缺少“Content-Security-Policy”头

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/dev-api/captchaImage>

实体: captchaImage (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 将您的服务器配置为使用“Content-Security-Policy”头

差异:

推理: AppScan 检测到 Content-Security-Policy 响应头缺失, 这可能会更大程度得暴露于各种跨站点注入攻击下之

未经处理的测试响应:

```
...
GET /dev-api/captchaImage HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:12:20 GMT
content-type: application/json; charset=UTF-8
pragma: no-cache
cache-control: no-cache, no-store, max-age=0, must-revalidate
transfer-encoding: chunked

{"msg": "操作成功", "img": "/9j/4AAQSkZJRgABAQAAQABAAQ/2wBDAAgGBgcGBQgHBwcJCQgKDBQNDAsLDBkSEw8UHRofHh0aHBWgJC4nIC
IsIxwKDcpLDaxNDQ0Hyc5PTgyPC4zNDI/2wBDAQkJCQwLDBg...
...
```

低

缺少“X-Content-Type-Options”头 ①

TOC

问题 1 / 1

TOC

缺少“X-Content-Type-Options”头

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/static/js/67.js>

实体: 67.js (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 将您的服务器配置为使用“X-Content-Type-Options”头

差异:

推理: AppScan 检测到 X-Content-Type-Options 响应头缺失, 这可能会更大程度得暴露于偷渡式下载攻击之下

未经处理的测试响应:

```
...
GET /static/js/67.js HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
Connection: keep-alive
Accept-Ranges: bytes
Content-Length: 102495
Keep-Alive: timeout=5
X-Powered-By: Express
ETag: W/"1905f-6RXUrf1m70QJ4/0kYdTab49hYJQ"
Date: Sat, 08 May 2021 04:12:21 GMT
Content-Type: application/javascript; charset=UTF-8

((typeof self !== 'undefined' ? self : this)["webpackJsonp"] = (typeof self !== 'undefined' ?
self : this)["webpackJsonp"] || []).push([[67],{
...

```

低

缺少“X-XSS-Protection”头 1

TOC

问题 1 / 1

TOC

缺少“X-XSS-Protection”头

严重性: 低

CVSS 分数: 5.0

URL: <http://sx.baway.tech:8060/static/js/67.js>

实体: 67.js (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 将您的服务器配置为使用“X-XSS-Protection”头

差异:

推理: AppScan 检测到 X-XSS-Protection 响应头缺失, 这可能会造成跨站点脚本编制攻击
未经处理的测试响应:

```
...
GET /static/js/67.js HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
Connection: keep-alive
Accept-Ranges: bytes
Content-Length: 102495
Keep-Alive: timeout=5
X-Powered-By: Express
ETag: W/"1905f-6RXUrf1m70QJ4/0kYdTab49hYJQ"
Date: Sat, 08 May 2021 04:12:21 GMT
Content-Type: application/javascript; charset=UTF-8

((typeof self !== 'undefined' ? self : this)["webpackJsonp"] = (typeof self !== 'undefined' ?
self : this)["webpackJsonp"] || []).push([[67],{
...

```

问题 1 / 1

TOC

HTML 注释敏感信息泄露

严重性: 参考

CVSS 分数: 0.0

URL: <http://sx.baway.tech:8060/>实体: `<link rel="icon" href="/favicon.ico">` (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置

原因: 程序员在 Web 页面上留下调试信息

固定值: 除去 HTML 注释中的敏感信息

差异:

推理: AppScan 发现了包含看似为敏感信息的 HTML 注释。

原始响应

```
...
<head>
  <meta charset="utf-8">
  <meta http-equiv="X-UA-Compatible" content="IE=edge,chrome=1">
  <meta name="renderer" content="webkit">
  <meta name="viewport" content="width=device-width, initial-scale=1, maximum-scale=1, user-
scalable=no">
  <!-- <link rel="icon" href="/favicon.ico"> -->
  <title>八维教育</title>
  <style>
    html,
    body,
    #app {
      height: 100%;
      margin: 0px;
      padding: 0px;
    }
  </style>
  ...
```

发现电子邮件地址模式	
严重性:	参考
CVSS 分数:	0.0
URL:	http://sx.baway.tech:8060/static/js/10.js
实体:	10.js (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	Web 应用程序编程或配置不安全
固定值:	除去 Web 站点中的电子邮件地址

差异:

推理: 响应包含可能是专用的电子邮件地址。

未经处理的测试响应:

```
...
...b.prototype, new ____();\r\n}\n\n// Hex JavaScript decoder\n// Copyright (c) 2008-2013 Lapo
Luchini <lapo@lapo.it>\n\n// Permission to use, copy, modify, and/or distribute this software for
any\n// purpose with or w...

...

...
...   return out;\n      }\n};\n\n// Base64 JavaScript decoder\n// Copyright (c) 2008-2013 Lapo
Luchini <lapo@lapo.it>\n\n// Permission to use, copy, modify, and/or distribute this software for
any\n// purpose with or w...

...

...
...code(a);\n      }\n};\n\n// Big integer base-10 printing library\n// Copyright (c) 2014 Lapo
Luchini <lapo@lapo.it>\n\n// Permission to use, copy, modify, and/or distribute this software for
any\n// purpose with or w...

...

...
...om/jsrsasign/license\n * /\n\n/**\n * @fileOverview\n * @name asn1-1.0.js\n * @author Kenji
Urushima <kenji.urushima@gmail.com>\n * @version asn1 1.0.13 (2017-Jun-02)\n * @since jsrsasign
2.1\n * @license <a href=\"https://kjur...
```

客户端 (JavaScript) Cookie 引用**严重性:** [参考](#)**CVSS 分数:** 0.0**URL:** <http://sx.baway.tech:8060/static/js/chunk-vendors.js>**实体:** ((typeof self !== 'undefined' ? self : this)["webpackJsonp"]) = (typeof self !== 'undefined' ? self : ... (Page)**风险:** 此攻击的最坏情形取决于在客户端所创建的 cookie 的上下文和角色**原因:** Cookie 是在客户端创建的**固定值:** 除去客户端中的业务逻辑和安全逻辑**差异:****推理:** AppScan 在 JavaScript 中找到对 cookie 的引用。**原始响应**

```
GET /static/js/chunk-vendors.js HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/53.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:8060/
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
Content-Type: text/html

<html>AppScan response: Request doesn't exist in cache.</html>
```

参

检测到应用程序测试脚本 **13**

TOC

检测到应用程序测试脚本

严重性: [参考](#)

CVSS 分数: 0.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: test (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去服务器中的测试脚本

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/test`

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求:

```
GET /dev-api/test HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

测试响应

```
...
GET /dev-api/test HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 83
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:46
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate
```

```
{"msg": "请求访问: /test, 认证失败,
无法访问系统资源", "code": 401}
```

```
...
```

检测到应用程序测试脚本**严重性:** [参考](#)**CVSS 分数:** 0.0**URL:** <http://sx.baway.tech:8060/dev-api/>**实体:** test.php (Page)**风险:** 可能会下载临时脚本文件，这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息**原因:** 在生产环境中留下临时文件**固定值:** 除去服务器中的测试脚本**差异:** **路径** 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/test.php`**推理:** AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。**测试请求:****测试响应**

```
GET /dev-api/test.php HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
...
GET /dev-api/test.php HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 87
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:46
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate
```

```
{"msg": "请求访问: /test.php, 认证失
败, 无法访问系统资源", "code": 401}
...
```

问题 3 / 13

TOC

检测到应用程序测试脚本

严重性: [参考](#)

CVSS 分数: 0.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: test.php3 (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去服务器中的测试脚本

差异: 路径 从以下位置进行控制: </dev-api/captchaImage> 至: </dev-api/test.php3>

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求:

```
GET /dev-api/test.php3 HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

测试响应

```
...
GET /dev-api/test.php3 HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 88
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:46
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate

{"msg": "请求访问: /test.php3, 认证
失败, 无法访问系统资源", "code": 401}
...
```

检测到应用程序测试脚本

严重性: [参考](#)

CVSS 分数: 0.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: test.asp (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去服务器中的测试脚本

差异: 路径 从以下位置进行控制: [/dev-api/captchaImage](#) 至: [/dev-api/test.asp](#)

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求:

```
GET /dev-api/test.asp HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

测试响应

```
...
GET /dev-api/test.asp HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 87
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:47
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate

{"msg": "请求访问: /test.asp, 认证失
败, 无法访问系统资源", "code": 401}
...
```

检测到应用程序测试脚本**严重性:** [参考](#)**CVSS 分数:** 0.0**URL:** <http://sx.baway.tech:8060/dev-api/>**实体:** test.aspx (Page)**风险:** 可能会下载临时脚本文件，这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息**原因:** 在生产环境中留下临时文件**固定值:** 除去服务器中的测试脚本**差异:** **路径** 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/test.aspx`**推理:** AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。**测试请求:****测试响应**

```
GET /dev-api/test.aspx HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
...
GET /dev-api/test.aspx HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 88
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:49
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate
```

```
{"msg": "请求访问: /test.aspx, 认证
失败, 无法访问系统资源", "code": 401}
...
```

问题 6 / 13

TOC

检测到应用程序测试脚本

严重性: [参考](#)

CVSS 分数: 0.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: test.cgi (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去服务器中的测试脚本

差异: 路径 从以下位置进行控制: </dev-api/captchaImage> 至: </dev-api/test.cgi>

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求:

```
GET /dev-api/test.cgi HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

测试响应

```
...
GET /dev-api/test.cgi HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 87
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:49
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate

{"msg":"请求访问: /test.cgi, 认证失
败, 无法访问系统资源","code":401}
...
```

检测到应用程序测试脚本

严重性: [参考](#)

CVSS 分数: 0.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: test.htm (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去服务器中的测试脚本

差异: 路径 从以下位置进行控制: </dev-api/captchaImage> 至: </dev-api/test.htm>

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求:

```
GET /dev-api/test.htm HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

测试响应

```
...
GET /dev-api/test.htm HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 87
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:49
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate
```

```
{"msg": "请求访问: /test.htm, 认证失
败, 无法访问系统资源", "code": 401}
...
```

检测到应用程序测试脚本**严重性:** 参考**CVSS 分数:** 0.0**URL:** <http://sx.baway.tech:8060/dev-api/>**实体:** test.cfm (Page)**风险:** 可能会下载临时脚本文件，这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息**原因:** 在生产环境中留下临时文件**固定值:** 除去服务器中的测试脚本**差异:** **路径** 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/test.cfm`**推理:** AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。**测试请求:****测试响应**

```
GET /dev-api/test.cfm HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
...
GET /dev-api/test.cfm HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 87
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:49
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate
```

```
{"msg": "请求访问: /test.cfm, 认证失
败, 无法访问系统资源", "code": 401}
...
```

问题 9 / 13

TOC

检测到应用程序测试脚本

严重性: [参考](#)

CVSS 分数: 0.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: test.pl (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去服务器中的测试脚本

差异: 路径 从以下位置进行控制: </dev-api/captchaImage> 至: </dev-api/test.pl>

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求:

```
GET /dev-api/test.pl HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

测试响应

```
...
GET /dev-api/test.pl HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8

HTTP/1.1 200 OK
content-length: 86
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:50
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate

{"msg": "请求访问: /test.pl, 认证失
败, 无法访问系统资源", "code": 401}
...
```

检测到应用程序测试脚本

严重性: [参考](#)

CVSS 分数: 0.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: test.dbf (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去服务器中的测试脚本

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/test.dbf`

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求:

```
GET /dev-api/test.dbf HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

测试响应

```
...
GET /dev-api/test.dbf HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 87
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:50
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate
```

```
{"msg": "请求访问: /test.dbf, 认证失
败, 无法访问系统资源", "code": 401}
...
```

检测到应用程序测试脚本**严重性:** [参考](#)**CVSS 分数:** 0.0**URL:** <http://sx.baway.tech:8060/dev-api/>**实体:** test.shtml (Page)**风险:** 可能会下载临时脚本文件，这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息**原因:** 在生产环境中留下临时文件**固定值:** 除去服务器中的测试脚本**差异:** **路径** 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/test.shtml`**推理:** AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。**测试请求:****测试响应**

```
GET /dev-api/test.shtml HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
...
GET /dev-api/test.shtml HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 89
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:50
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate
```

```
{"msg": "请求访问: /test.shtml, 认证
失败, 无法访问系统资源", "code": 401}
...
```

问题 12 / 13

TOC

检测到应用程序测试脚本

严重性: [参考](#)

CVSS 分数: 0.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: test.txt (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去服务器中的测试脚本

差异: 路径 从以下位置进行控制: </dev-api/captchaImage> 至: </dev-api/test.txt>

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求:

```
GET /dev-api/test.txt HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

测试响应

```
...
GET /dev-api/test.txt HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 87
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:50
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate
```

```
{"msg": "请求访问: /test.txt, 认证失
败, 无法访问系统资源", "code": 401}
...
```

检测到应用程序测试脚本

严重性: [参考](#)

CVSS 分数: 0.0

URL: <http://sx.baway.tech:8060/dev-api/>

实体: test.jsp (Page)

风险: 可能会下载临时脚本文件, 这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

原因: 在生产环境中留下临时文件

固定值: 除去服务器中的测试脚本

差异: 路径 从以下位置进行控制: `/dev-api/captchaImage` 至: `/dev-api/test.jsp`

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求:

```
GET /dev-api/test.jsp HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

测试响应

```
...
GET /dev-api/test.jsp HTTP/1.1
User-Agent: Mozilla/5.0 (Windows
NT 10.0; WOW64) AppleWebKit/537.
36 (KHTML, like Gecko) Chrome/53
.0.2785.116 Safari/537.36
Referer: http://sx.baway.tech:80
60/login?redirect=%2FhighPost
Connection: keep-alive
Host: sx.baway.tech:8060
Accept: application/json, text/p
lain, */*
Accept-Language: en-US,en;q=0.8
```

```
HTTP/1.1 200 OK
content-length: 87
x-content-type-options: nosniff
expires: 0
X-Powered-By: Express
x-xss-protection: 1; mode=block
connection: close
date: Sat, 08 May 2021 04:19:51
GMT
content-type: application/json;c
harset=utf-8
pragma: no-cache
cache-control: no-cache, no-stor
e, max-age=0, must-revalidate

{"msg": "请求访问: /test.jsp, 认证失
败, 无法访问系统资源", "code": 401}
...
```

修订建议

高

阻止对 PL/SQL 过程和应用程序进行未认证的 PUBLIC 访问

TOC

该任务修复的问题类型

- Oracle Application Server PL/SQL 未授权的 SQL 查询执行

常规

在“\$ORACLE_HOME\$Apache\modplsql\cfg\wdbsvr.app”文件中添加下列规则来封锁对于 PL/SQL 过程和应用程序未经认证的 PUBLIC 访问：

exclusion_list= account*, sys.*, dbms_*, owa*

低

不要在可以轻易猜测到的文件名中保存敏感信息，或者限制对它们的访问

TOC

该任务修复的问题类型

- 发现潜在订单信息

常规

敏感信息（例如：订单信息、注册表信息，等等）不应放在很容易猜测的文件名中，但倘若必须如此，请限制访问所说的文件。

低

关闭跟踪，限制对日志文件的访问，或者将其除去

TOC

该任务修复的问题类型

- Oracle 日志文件信息泄露

常规

关闭跟踪，限制日志和跟踪文件的访问权，或删除它们。

低

将您的服务器配置为使用“Content-Security-Policy”头

TOC

该任务修复的问题类型

- 缺少“Content-Security-Policy”头

常规

将您的服务器配置为发送“Content-Security-Policy”头。对于 Apache，请参阅：

http://httpd.apache.org/docs/2.2/mod/mod_headers.html

对于 IIS，请参阅：

<https://technet.microsoft.com/pl-pl/library/cc753133%28v=ws.10%29.aspx>

对于 nginx，请参阅：

http://nginx.org/en/docs/http/nginx_http_headers_module.html

低

将您的服务器配置为使用“X-Content-Type-Options”头

TOC

该任务修复的问题类型

- 缺少“X-Content-Type-Options”头

常规

将您的服务器配置为在所有传出请求上发送值为“nosniff”的“X-Content-Type-Options”头。对于 Apache，请参阅：

http://httpd.apache.org/docs/2.2/mod/mod_headers.html

对于 IIS，请参阅：

<https://technet.microsoft.com/pl-pl/library/cc753133%28v=ws.10%29.aspx>

对于 nginx，请参阅：

http://nginx.org/en/docs/http/nginx_http_headers_module.html

低

将您的服务器配置为使用“X-XSS-Protection”头

TOC

该任务修复的问题类型

- 缺少“X-XSS-Protection”头

常规

将您的服务器配置为在所有传出请求上发送值为“1”（例如已启用）的“X-XSS-Protection”头。对于 Apache，请参阅：
http://httpd.apache.org/docs/2.2/mod/mod_headers.html

对于 IIS，请参阅：

<https://technet.microsoft.com/pl-pl/library/cc753133%28v=ws.10%29.aspx>

对于 nginx，请参阅：

http://nginx.org/en/docs/http/ngx_http_headers_module.html

低

除去 HTML 注释中的敏感信息

TOC

该任务修复的问题类型

- HTML 注释敏感信息泄露

常规

[1] 请勿在 HTML 注释中遗留任何重要信息（如文件名或文件路径）。

[2] 从生产站点注释中除去以前（或未来）站点链接的跟踪信息。

[3] 避免在 HTML 注释中放置敏感信息。

[4] 确保 HTML 注释不包括源代码片段。

[5] 确保程序员没有遗留重要信息。

低

除去 Web 站点中的电子邮件地址

TOC

该任务修复的问题类型

- 发现电子邮件地址模式

常规

从 **Web** 站点中除去任何电子邮件地址，以便其不会被恶意用户利用。

低

除去压缩目录文件或限制对它的访问

TOC

该任务修复的问题类型

- 发现压缩目录

常规

除去或约束对压缩目录文件的访问权。

低

除去客户端中的业务逻辑和安全逻辑

TOC

该任务修复的问题类型

- 客户端（JavaScript）Cookie 引用

常规

[1] 避免在客户端放置业务/安全逻辑。

[2] 查找并除去客户端不安全的 **JavaScript** 代码，该代码可能会对站点造成安全威胁。

低

除去服务器中的测试脚本

TOC

该任务修复的问题类型

- 检测到应用程序测试脚本

常规

不可将测试/暂时脚本遗留在服务器上，未来要避免出现这个情况。
确保服务器上没有非正常操作所必备的其他脚本。

低

除去虚拟目录中的旧版本文件

TOC

该任务修复的问题类型

- 临时文件下载
- 归档文件下载

常规

临时文件下载

请勿将文件的备份/暂存版本归档在虚拟 **Web** 服务器根目录之下。这通常在编辑器“就地”编辑这些文件之时发生。相反地，当升级站点时，请将文件移动或复制到虚拟根目录以外的目录、在这个目录中编辑文件，然后再将文件移动（或复制）回虚拟根目录。请确保，在虚拟根目录下，只有实际在使用的文件。

归档文件下载

请勿将文件的归档版本存放在虚拟 **Web** 服务器根目录之下。相反地，请将归档文件存放在虚拟根之外。请确保，在虚拟根目录下，只有实际在使用的文件。

咨询

Oracle Application Server PL/SQL 未授权的 SQL 查询执行

[TOC](#)

测试类型:

基础结构测试

威胁分类:

SQL 注入

原因:

Web 应用程序编程或配置不安全

安全性风险:

可能会查看、修改或删除数据库条目和表

受影响产品:

CVE:

CVE-2002-0560

CWE:

89

X-Force:

8451

引用:

供应商站点

BugTraq BID: 4294

“Oracle Application Server 防骇”，作者: David Litchfield

技术描述:

缺省情况下，Oracle Application Server 会安装 OWA_UTIL PL/SQL 程序包，任何用户都可以访问它。这个程序包会显现若干过程，可让用户执行任意 SQL 查询。利用的样本: [1] 这个请求会返回 sys 模式中 dba_users 表格中的前

100 列:

GET /pls/DAD_NAME/owa_util.cellsprint?p_theQuery=select%20*%20from%20sys.dba_users HTTP/1.0

[2] 这个请求会返回 dba_users 表中的列:

GET /pls/DAD_NAME/owa_util.show_query_columns?ctable=sys.dba_users HTTP/1.0

注意: “DAD_NAME”应该改成符合测试的 Web 应用程序。

Oracle 日志文件信息泄露

TOC

测试类型:

基础结构测试

威胁分类:

信息泄露

原因:

Web 服务器或应用程序服务器是以不安全的方式配置的

安全性风险:

可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置

受影响产品:

CWE:

200

X-Force:

52270

引用:

FrontPage 服务器扩展: 安全考虑

技术描述:

Oracle 有一个称为“sqlnet.log”的日志文件, 以及一个称为“sqlnet.trc”的跟踪文件。这些文件包含跟踪输出和错误消息, 可能会显现敏感性信息。

攻击者可以利用这个问题来获取关于服务器机器的敏感信息, 从而进一步攻击站点。利用的样本如下:

http://[SERVER]/sqlnet.log

http://[SERVER]/sqlnet.trc

临时文件下载

TOC

测试类型:

应用程序级别测试

威胁分类:

可预测资源位置

原因:

在生产环境中留下临时文件

安全性风险:

受影响产品:

CWE:

531

X-Force:

52887

引用:

WASC 威胁分类: 可预期的资源位置

技术描述:

Web 服务器通常会使用“公共网关接口 (CGI)”文件扩展名 (如 .pl) 与 Perl 之类的某个处理程序相关联。当 URL 路径结尾是 .pl 时, 路径所指定的文件名会发送给 Perl 执行; 文件内容不会返回给浏览器。然而, 当在适当的位置编辑脚本文件时, 编辑器可以用新的文件扩展名来保存所编辑的脚本的备份副本, 例如: .bak、.sav、.old、~ 等等。Web 服务器通常没有这些文件扩展名的特定处理程序。如果攻击者请求这类文件, 文件内容会直接发送到浏览器。从虚拟目录下除去这些临时文件很重要, 因为它们可能含有调试目的所用的敏感信息, 也可能显露有并非当前逻辑, 但仍可能受到利用的应用程序逻辑攻击。

发现压缩目录

TOC

测试类型:

基础结构测试

威胁分类:

信息泄露

原因:

Web 应用程序编程或配置不安全

安全性风险:

可能会检索服务器端脚本的源代码, 这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

受影响产品:

CWE:

200

X-Force:

52517

技术描述:

AppScan 找到了可能含有整个目录内容的压缩文件。
这是通过安装压缩文件扩展名来请求目录名称而进行的, 例如:

```
GET /DIR1.zip HTTP/1.0
```

or

```
GET /DIR2.gz HTTP/1.0
```

这个文件可能含有目录的最新或过期内容。
不论任何情况, 恶意的用户都有可能通过猜测文件名, 而得以访问源代码和不具特权的文件。利用的样本如下:
`http://[SERVER]/[DIR].zip`

发现潜在订单信息

TOC

测试类型:

应用程序级别测试

威胁分类:

信息泄露

原因:

Web 应用程序编程或配置不安全

安全性风险:

可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置

受影响产品：

CWE:

538

X-Force:

52843

技术描述：

电子商务应用程序可能以直接明确的名称（如 `order.txt`）来存储敏感订单信息，攻击者很容易猜测及检索这些名称。利用的样本如下：

`http://[SERVER]/order.txt`

归档文件下载

[TOC](#)

测试类型：

应用程序级别测试

威胁分类：

[可预测资源位置](#)

原因：

在生产环境中留下临时文件

安全性风险：

受影响产品：

CWE:

531

X-Force:

52496

引用：

[WASC 威胁分类：可预期的资源位置](#)

技术描述：

Web 服务器通常会使用“公共网关接口（CGI）”文件扩展名（如 `.pl`）与 Perl 之类的某个处理程序相关联。当 URL 路径

结尾是 .pl 时，路径所指定的文件名会发送给 Perl 执行；文件内容不会返回给浏览器。不过，当归档脚本文件时，会创建一个 ARC 文件。Web 服务器通常没有处理这个文件扩展名的特定处理程序。如果攻击者请求这个文件，文件内容会直接发送到浏览器。

缺少“Content-Security-Policy”头

TOC

测试类型：

应用程序级别测试

威胁分类：

信息泄露

原因：

Web 应用程序编程或配置不安全

安全性风险：

- 可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
- 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息

受影响产品：

CWE：

200

引用：

有用 HTTP 头的列表
内容安全策略的简介

技术描述：

“Content-Security-Policy”头设计用于修改浏览器渲染页面的方式，并因此排除各种跨站点注入，包括跨站点脚本编制。以不会阻止 web 站点的正确操作的方式正确地设置头值就非常的重要。例如，如果头设置为阻止内联 JavaScript 的执行，那么 web 站点不得在其页面中使用内联 JavaScript。

缺少“X-Content-Type-Options”头

TOC

测试类型：

应用程序级别测试

威胁分类:

信息泄露

原因:

Web 应用程序编程或配置不安全

安全性风险:

- 可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
- 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息

受影响产品:

CWE:

200

引用:

有用 HTTP 头的列表

减小 MIME 类型安全性风险

技术描述:

“X-Content-Type-Options”头（具有“nosniff”值）可防止 IE 和 Chrome 忽略响应的内容类型。该操作可能防止在用户浏览器中执行不受信任的内容（例如用户上传的内容）（例如在恶意命名之后）。

缺少“X-XSS-Protection”头

TOC

测试类型:

应用程序级别测试

威胁分类:

信息泄露

原因:

Web 应用程序编程或配置不安全

安全性风险:

- 可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
- 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息

受影响产品:

CWE:

200

引用:

有用 HTTP 头的列表
IE XSS 过滤器

技术描述:

“X-XSS-Protection”头强制将跨站点脚本编制过滤器加入“启用”方式，即使用户已禁用时也是如此。该过滤器被构建到最新的 web 浏览器中（IE 8+，Chrome 4+），通常在缺省情况下已启用。虽然它并非设计为第一个选择而且仅能防御跨站点脚本编制，但它充当额外的保护层。

HTML 注释敏感信息泄露

TOC

测试类型:

应用程序级别测试

威胁分类:

信息泄露

原因:

程序员在 Web 页面上留下调试信息

安全性风险:

可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置

受影响产品:

CWE:

615

X-Force:

52601

引用:

WASC 威胁分类: 信息泄露

技术描述:

很多 Web 应用程序程序员使用 HTML 注释，以在需要时帮助调试应用程序。尽管添加常规注释有助于调试应用程序，但一些程序员往往会遗留重要数据（例如：与 Web 应用程序相关的文件名、旧的链接或原非供用户浏览的链接、旧的代码片段等）。

发现电子邮件地址模式

TOC

测试类型:

应用程序级别测试

威胁分类:

信息泄露

原因:

Web 应用程序编程或配置不安全

安全性风险:

可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置

受影响产品:

CWE:

359

X-Force:

52584

引用:

[Spambot 的定义（维基百科）](#)

技术描述:

Spambot 搜寻因特网站点，开始查找电子邮件地址来构建发送自发电子邮件（垃圾邮件）的邮件列表。

AppScan 检测到含有一或多个电子邮件地址的响应，可供利用以发送垃圾邮件。

而且，找到的电子邮件地址也可能是专用电子邮件地址，对于一般大众应是不可访问的。

客户端（JavaScript）Cookie 引用

TOC

测试类型:

应用程序级别测试

威胁分类:

信息泄露

原因:

Cookie 是在客户端创建的

安全性风险:

此攻击的最坏情形取决于在客户端所创建的 cookie 的上下文和角色

受影响产品:

CWE:

602

X-Force:

52514

引用:

WASC 威胁分类: 信息泄露

技术描述:

cookie 是一则信息，通常由 Web 服务器创建并存储在 Web 浏览器中。

web 应用程序主要（但不只是）使用 cookie 包含的信息来识别用户并维护用户的状态。

AppScan 检测到客户端上的 JavaScript 代码用于操控（创建或修改）站点的 cookie。

攻击者有可能查看此代码、了解其逻辑并根据所了解的知识将其用于组成其自己的 cookie，或修改现有 cookie。

攻击者可能导致的损坏取决于应用程序使用其 cookie 的方式或应用程序存储在这些 cookie 中的信息内容。

此外，cookie 操控还可能导致会话劫持或特权升级。

由 cookie 毒害导致的其他漏洞包含 SQL 注入和跨站点脚本编制。

检测到应用程序测试脚本

TOC

测试类型:

应用程序级别测试

威胁分类:

可预测资源位置

原因:

在生产环境中留下临时文件

安全性风险:

可能会下载临时脚本文件，这会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息

CWE:

531

X-Force:

52497

技术描述:

公共用户可以通过简单的冲浪（即按照 **Web** 链接）来访问站点上的特定页面。不过，也有页面和脚本可能无法通过简单的冲浪来访问（即未链接的页面和脚本）。

攻击者也许能够通过猜测名称（例如 **test.php**、**test.asp**、**test.cgi**、**test.html** 等）来访问这些页面。

名为“**test.php**”的脚本的请求示例

`http://[SERVER]/test.php`

有时开发者会忘记从生产环境中除去某些调试或测试页面。这些页面有可能包括 **Web** 用户所不应访问的敏感信息。它们也可能易受到攻击，且/或有助于攻击者获取服务器的相关信息，以帮助进行攻击。利用的样本如下：

`http://[SERVER]/test.php`

`http://[SERVER]/test.asp`

`http://[SERVER]/test.aspx`

`http://[SERVER]/test.html`

`http://[SERVER]/test.cfm`

`http://[SERVER]/test.cgi`

应用程序数据

已访问的 URL 7

TOC

URL
http://sx.baway.tech:8060/
http://sx.baway.tech:8060/static/js/app.js
http://sx.baway.tech:8060/static/js/67.js
http://sx.baway.tech:8060/static/js/10.js
http://sx.baway.tech:8060/static/js/chunk-vendors.js
http://sx.baway.tech:8060/dev-api/captchaimage
http://sx.baway.tech:8060/dev-api/login

参数 5

TOC

名称	值	URL	类型
->"code"	32	http://sx.baway.tech:8060/dev-api/login	JSON
->"username"	32	http://sx.baway.tech:8060/dev-api/login	JSON
->"password"	123456	http://sx.baway.tech:8060/dev-api/login	JSON
->"uuid"	01d2a348477347d5bc65aff88a2cd612	http://sx.baway.tech:8060/dev-api/login	JSON
->"key"	student	http://sx.baway.tech:8060/dev-api/login	JSON

失败的请求 0

TOC

URL	原因
-----	----

已过滤的 URL 7

TOC

URL	原因
http://172.27.2.6:8060/sockjs-node/info?t=1620446794961	未测试的 Web Server
http://172.27.2.6:8060/sockjs-node/iframe.html	未测试的 Web Server
http://172.27.2.6:8060/__webpack_dev_server__/sockjs.bundle.js	未测试的 Web Server
http://172.27.2.6:8060/sockjs-node/227/sypqorv2/xhr?t=1620446802950	未测试的 Web Server
http://172.27.2.6:8060/sockjs-node/227/sypqorv2/xhr?t=1620446802959	未测试的 Web Server
http://172.27.2.6:8060/sockjs-node/227/1ajg4ywi/xhr_streaming?t=1620446795673	未测试的 Web Server
http://172.27.2.6:8060/sockjs-node/227/hvhu2z12/eventsouce	未测试的 Web Server

注释 1

TOC

URL	注释
http://sx.baway.tech:8060/	<link rel="icon" href="/favicon.ico">

JavaScript 4

TOC

URL / 代码
http://sx.baway.tech:8060/static/js/app.js

```

/*****/ (function(modules) { // webpackBootstrap
/*****/ // install a JSONP callback for chunk loading
/*****/ function webpackJsonpCallback(data) {
/*****/     var chunkIds = data[0];
/*****/     var moreModules = data[1];
/*****/     var executeModules = data[2];
/*****/
/*****/     // add "moreModules" to the modules object,
/*****/     // then flag all "chunkIds" as loaded and fire callback
/*****/     var moduleId, chunkId, i = 0, resolves = [];
/*****/     for(;i < chunkIds.length; i++) {
/*****/         chunkId = chunkIds[i];
/*****/         if(Object.prototype.hasOwnProperty.call(installedChunks, chunkId) &&
installedChunks[chunkId]) {
/*****/             resolves.push(installedChunks[chunkId][0]);
/*****/         }
/*****/         installedChunks[chunkId] = 0;
/*****/     }
/*****/     for(moduleId in moreModules) {
/*****/         if(Object.prototype.hasOwnProperty.call(moreModules, moduleId)) {
/*****/             modules[moduleId] = moreModules[moduleId];
/*****/         }
/*****/     }
/*****/     if(parentJsonpFunction) parentJsonpFunction(data);
/*****/
/*****/     while(resolves.length) {
/*****/         resolves.shift()();
/*****/     }
/*****/
/*****/     // add entry modules from loaded chunk to deferred list
/*****/     deferredModules.push.apply(deferredModules, executeModules || []);

```

```

/*****/
/*****/      // run deferred modules when all chunks ready
/*****/      return checkDeferredModules();
/*****/
/*****/    };
/*****/    function checkDeferredModules() {
/*****/      var result;
/*****/      for(var i = 0; i < deferredModules.length; i++) {
/*****/        var deferredModule = deferredModules[i];
/*****/        var fulfilled = true;
/*****/        for(var j = 1; j < deferredModule.length; j++) {
/*****/          var depId = deferredModule[j];
/*****/          if(installedChunks[depId] !== 0) fulfilled = false;
/*****/        }
/*****/        if(fulfilled) {
/*****/          deferredModules.splice(i--, 1);
/*****/          result = __webpack_require__(__webpack_require__.s =
deferredModule[0]);
/*****/        }
/*****/      }
/*****/      return result;
/*****/    }
/*****/    function hotDisposeChunk(chunkId) {
/*****/      delete installedChunks[chunkId];
/*****/    }
/*****/    var parentHotUpdateCallback = (typeof self !== 'undefined' ? self : this)
["webpackHotUpdate"];
/*****/    (typeof self !== 'undefined' ? self : this)["webpackHotUpdate"] = // eslint-disable-next-line
no-unused-vars
/*****/    function webpackHotUpdateCallback(chunkId, moreModules) {
/*****/      hotAddUpdateChunk(chunkId, moreModules);
/*****/      if (parentHotUpdateCallback) parentHotUpdateCallback(chunkId, moreModules);
/*****/    };
/*****/
/*****/    // eslint-disable-next-line no-unused-vars
/*****/    function hotDownloadUpdateChunk(chunkId) {
/*****/      var script = document.createElement("script");
/*****/      script.charset = "utf-8";
/*****/      script.src = __webpack_require__.p + "" + chunkId + "." + hotCurrentHash + ".hot-
update.js";
/*****/      if (null) script.crossOrigin = null;
/*****/      document.head.appendChild(script);
/*****/    }
/*****/
/*****/    // eslint-disable-next-line no-unused-vars
/*****/    function hotDownloadManifest(requestTimeout) {
/*****/      requestTimeout = requestTimeout || 10000;
/*****/      return new Promise(function(resolve, reject) {
/*****/        if (typeof XMLHttpRequest === "undefined") {
/*****/          return reject(new Error("No browser support"));
/*****/        }
/*****/        try {
/*****/          var request = new XMLHttpRequest();
/*****/          var requestPath = __webpack_require__.p + "" + hotCurrentHash +
".hot-update.json";
/*****/          request.open("GET", requestPath, true);
/*****/          request.timeout = requestTimeout;
/*****/          request.send(null);
/*****/        } catch (err) {
/*****/          return reject(err);
/*****/        }
/*****/        request.onreadystatechange = function() {
/*****/          if (request.readyState !== 4) return;
/*****/          if (request.status === 0) {
/*****/            // timeout
/*****/            reject(
/*****/              new Error("Manifest request to " + requestPath + "
timed out.");
/*****/            );
/*****/          } else if (request.status === 404) {
/*****/            // no update available
/*****/            resolve();
/*****/          } else if (request.status !== 200 && request.status !== 304) {
/*****/            // other failure
/*****/            reject(new Error("Manifest request to " + requestPath + "
failed."));
/*****/          } else {
/*****/            // success

```


http://sx.baway.tech:8060/static/js/10.js

http://sx.baway.tech:8060/static/js/chunk-vendors.js

```

typeof self != 'undefined' ? self : this) ["webpackJsonp"] = (typeof self !== 'undefined' ? self : this)
["webpackJsonp"] || []).push([["chunk-vendors"],{

/***/ "./node_modules/@babel/runtime/helpers/arrayLikeToArray.js":
/*!*****!*\
  !*** ./node_modules/@babel/runtime/helpers/arrayLikeToArray.js ***!
  \*****/
/*! no static exports found */
/***/ (function(module, exports) {

eval("function _arrayLikeToArray(arr, len) {\n if (len == null || len > arr.length) len = arr.length;\n\n for (var i = 0, arr2 = new Array(len); i < len; i++) {\n   arr2[i] = arr[i];\n }\n\n return arr2;\n}\n\nmodule.exports = _arrayLikeToArray;\n\nmodule.exports[\"default\"] = module.exports,\nmodule.exports.__esModule = true;/** sourceURL=[module]\n\n//\nsourceMappingURL=data:application/json;charset=utf-8;base64,eYJ2ZXJzaW9uIjozLCJmaWxlIjoLi9ub2RlX21vZHVzZXNMvQGJhYmVsL3J1bnRpbWUvaGVscGVycy9hcnJheUxpa2VUb0FycmF5LmpzLmpzIiwic291cmNlcYi6WyJ3ZWJwYWNRDi8vLy4vbW9kZV9tbn2R1bGVzL0BjYVJwLjBcYydW50aW1lL2hlbHBlcnMvYXJyYXlMaWtlVG9BcnJheS5qc281YTQzIl0sInNvdXJjZXNDb250ZW50IjpjbImZlbmN0aW9uIF9hcnJheUxpa2VUb0FycmF5KGFyciwiYmVudGluZSB7XG4gIGlmIchsZW4gPT0gbnVsbCB8fCbsZW4gPiBhcnIubGvuZ3RoKSBSZW4gPSBhcnIubGvuZ3RoO1xuXG4gIGZvciaOdMfyIGkgPSAwLCBhcnIyID0gbmV3IEFycmF5KGxlbik7IGkgPCBsZW47IGkrKykgelxuCAGIGFycjJbaV0gPSBhcnJbaV07XG4gIH1chlxuICByZXRlc4gYXJyMjtcbnlcb1xubW9kdWxLMlMv4CG9dHMGPsfBYXJyYXlMaWtlVG9BcnJheTtcblmvZHVsZSS5leHBvcnRzWlwiZGVMYXVsdfWiXSA9IGlvZHVsZSS5leHBvcnRzLCBtb2R1bGUuZXhw3J0cy5fX2VzTW9kdWxIID0gdHJ1ZTSiXSuibWFwcGluz3MiOiJBQUFBQ0FBQ0E7QUFDQTtBQUNBO0FBQ0E7QUFDQSIsInNvdXJjZVJvb3QiOiIfQ==\n\n// sourceURL=webpack-internal:///./node_modules/@babel/runtime/helpers/arrayLikeToArray.js\n");

/***/ }),

/***/ "./node_modules/@babel/runtime/helpers/arrayWithHoles.js":
/*!*****!*\
  !*** ./node_modules/@babel/runtime/helpers/arrayWithHoles.js ***!
  \*****/
/*! no static exports found */
/***/ (function(module, exports) {

eval("function _arrayWithHoles(arr) {\n if (Array.isArray(arr)) return arr;\n}\n\n\nmodule.exports = _arrayWithHoles;\n\nmodule.exports[\"default\"] = module.exports, module.exports.__esModule = true;/** sourceURL=[module]\n\n//\nsourceMappingURL=data:application/json;charset=utf-8;base64,eYJ2ZXJzaW9uIjozLCJmaWxlIjoLi9ub2RlX21vZHVzZXNMvQGJhYmVsL3J1bnRpbWUvaGVscGVycy9hcnJheVdpdGhI2xlcysqcy5qcYisInNvdXJjZXNiOlslid2VicGFjazovLy8uL25vZGVfbW9kdWxlcY9AYmFiZWwvcnVudGltZS9oZWxzXzJzL2FycmF5V2l0aEhvbgVzLmpzP2MzMzUiXSwic291cmNlc0NvbmlRlnbQ10slidnVuY3Rpb24gP2FycmF5V2l0aEhvbgVzKGFycikgelxuCIBpZiAoXJyYXkuXNBcnJheShhcnIpKSByZXRlc4gYXJyO1xufVxuXG5tb2R1bGUuZXhw3J0cyA9IF9hcnJheVdpdGhI2xlcztcbmlvZHVzZSS5leHBvcnRzWlwiZGVMYXVsdfWiXSA9IGlvZHVsZSS5leHBvcnRzLCBtb2R1bGUuZXhw3J0cy5fX2VzTW9kdWxIID0gdHJ1ZTSiXSuibWFwcGluz3MiOiJBQUFBQ0FBQ0E7QUFDQTtBQUNBO0FBQ0E7QUFDQSIsInNvdXJjZVJvb3QiOiIfQ==\n\n// sourceURL=webpack-internal:///./node_modules/@babel/runtime/helpers/arrayWithHoles.js\n");

/***/ }),

/***/ "./node_modules/@babel/runtime/helpers/arrayWithoutHoles.js":
/*!*****!*\
  !*** ./node_modules/@babel/runtime/helpers/arrayWithoutHoles.js ***!
  \*****/
/*! no static exports found */
/***/ (function(module, exports, __webpack_require__) {

eval("var arrayLikeToArray = __webpack_require__(/*! ./arrayLikeToArray.js */\n\n\"./node_modules/@babel/runtime/helpers/arrayLikeToArray.js\") ;\n\n\nfunction _arrayWithoutHoles(arr) {\n if (Array.isArray(arr)) return arrayLikeToArray(arr);\n }\n\n\nmodule.exports = _arrayWithoutHoles;\n\nmodule.exports[\"default\"] = module.exports, module.exports.__esModule = true;/** sourceURL=[module]\n\n//\nsourceMappingURL=data:application/json;charset=utf-8;base64,eYJ2ZXJzaW9uIjozLCJmaWxlIjoLi9ub2RlX21vZHVzZXNMvQGJhYmVsL3J1bnRpbWUvaGVscGVycy9hcnJheVdpdGhvdXRib2xlcysqcYisInNvdXJjZXNiOlslid2VicGFjazovLy8uL25vZGVfbW9kdWxlcY9AYmFiZWwvcnVudGltZS9oZWxzXzJzL2FycmF5V2l0aG9ldEhvbgVzLmpzP2IYMzYiXSwic291cmNlc0NvbmlRlnbQ10slidnfyIGFycmF5TGlrZVRvQXJyYXkgPSByZXFlaXJlKFwiLi9hcnJheUxpa2VUb0FycmF5LmpzLmpzIiwic291cmNlcYjdGlbviBFYXJyYXlXaXRob3V0SG9sZXMOYXJyKSBB7XG4gIGlmIchBcnJheS5pc0FycmF5KGFycikIHJldHVyb1BhcncJheUxpa2VUb0FycmF5KGFycik7XG59XG5cbmlvZHVzZSS5leHBvcnRzID0gX2FycmF5V2l0aG9ldEhvbgVzOlxubW9kdWxLMlMv4CG9dHNBXCjkZWZhDwXOCJdID0gbW9kdWxLMlMv4CG9dHMSIGlvZHVsZSS5leHBvcnRzL19fZXNNb2R1bGUgPSB0cnVloYJdLCtYXBwaW5ncyI6IHRBQUE7QUFDQTtBQUNBO0FBQ0E7QUFDQTtBQUNBO0FBQ0E7QUFDQSIsInNvdXJjZVJvb3QiOiIfQ==\n\n// sourceURL=webpack-internal:///./node_modules/@babel/runtime/helpers/arrayWithoutHoles.js\n");

/***/ }),

/***/ "./node_modules/@babel/runtime/helpers/asyncToGenerator.js":
/*!*****!*\
  !*** ./node_modules/@babel/runtime/help...

```

名称	首先设置	域	安全
值	请求的 URL		到期